

T1.4.C — Endpoint /internal/usuario-resumen

Backend read-only para datos del dashboard · HMAC interno

Owner: Celestino · 2026-05-03 · Branch **pr/t1.4.c-usuario-resumen** · Commit **9030bec**

Status: Branch pusheado a GitHub. 21 tests nuevos verdes. Suite total **575 passed** (554 → 575). Read-only verificado por test que cuenta filas antes/después. **NO mergeado a main.**

1. Archivos modificados / creados

Archivo	Δ líneas	Tipo	Rol
agent/main.py	+151 / -0	M	Endpoint POST /internal/usuario-resumen + comentario de diseño
tests/test_main_internal_usuario_resumen.py	+479 / -0	A	21 tests cubriendo auth, JSON, payload, 404, casos felices, estados,
TOTAL	+630 / -0	2 archivos	

2. Endpoint creado

Ruta y firma

```
POST /internal/usuario-resumen
Headers:
  Content-Type: application/json
  X-Internal-Signature:
Body: {"subscription_id": "sub_xxx"}
```

Códigos HTTP

Status	Cuándo
401	Header X-Internal-Signature ausente o firma inválida
400	JSON malformado, no es objeto, o falta subscription_id
404	subscription_id no existe en suscripcion_stripe
200	Caso feliz: JSON con la estructura del response

3. Formato input / output

Input

```
{
  "subscription_id": "sub_xxx"
}
```

Output (200)

```
{
  "usuario": {
    "id": "sub_xxx",           // = subscription_id
    "email": null,            // backend no lo persiste; landing
                                // merge con session.user.email
    "telefono": "14076936023"
  },
  "creditos": {
    "saldo_actual": 170,
    "creditos_mensuales": 100, // del plan vigente
    "ultimo_movimiento": {     // null si no hay transacciones
      "delta": 100,
      "razon": "Renovación premium (100 créditos)",
      "saldo_resultante": 170,
      "creado": "2026-05-02T..."
    }
  },
  "suscripcion": {
    "estado": "active",       // active / past_due / canceled
    "plan": "premium",        // premium / pro
    "stripe_customer_id": "cus_xxx",
    "stripe_subscription_id": "sub_xxx",
    "current_period_end": null, // Stripe SDK desde landing
    "cancel_at_period_end": false, // Stripe SDK desde landing
    "actualizado": "2026-05-02T..."
  },
  "transacciones_recientes": [ // hasta 10, más reciente primero
    {"delta": 100, "razon": "...",
     "saldo_resultante": 170, "creado": "..."}
  ],
  "resumen": {
    "puede_cancelar": true,    // (estado == active)
    "dashboard_ready": true
  }
}
```

4. Cómo se valida HMAC

Reusa la función `_verificar_firma_interna(body, sig_header)` de `agent/main.py` (creada en T1.3.D para `/internal/stripe-event`). El patrón es idéntico:

```
def _verificar_firma_interna(body: bytes, sig_header: str) -> bool:
    secret = os.getenv("INTERNAL_BRIDGE_SECRET", "").strip()
    if not secret or not sig_header:
        return False
    esperado = hmac.new(
        secret.encode("utf-8"), body, hashlib.sha256
    ).hexdigest()
    return hmac.compare_digest(esperado, sig_header.strip())
```

Se firma el **body crudo exacto** antes de parsear JSON. Si la firma falla, el endpoint responde 401 sin tocar el body. `compare_digest` evita timing oracles.

Decisión: reusar INTERNAL_BRIDGE_SECRET

- Ya existe en Vercel y Render (mismo valor, validado en T1.3.E).
- Ya está documentada en .env.example.
- Reduce superficie de configuración.
- El endpoint de T1.4.C tiene el mismo perfil de riesgo que /internal/stripe-event (interno, sin acceso público), justifica compartir secret.

5. Identificador elegido: subscription_id

Opción	Decisión
stripe_customer_id (cus_xxx)	Rechazada · 1 customer puede tener varias subs históricas, ambigua
email	Rechazada · backend no persiste email del Stripe customer; habría que aceptar email + hacer lookup costoso v
telefono	Rechazada · expondría el teléfono en el caller; el landing no lo conoce sin un round-trip extra
user_id	N/A · no existe tabla 'usuarios' en backend
subscription_id (sub_xxx) ELEGIDA · PK de SuscripcionStripe (lookup O(1)). La sesión NextAuth ya lo tiene tras T1.4.B. Forjar ID	

6. Comandos ejecutados y resultado

Comando	Resultado
pytest tests/test_main_internal_usuario_resumen.py -x	21 passed in 39.19s
pytest --tb=short -q (suite completa)	575 passed in 305.63s · Δ +21 vs baseline 554

Cobertura de tests (21 nuevos)

Clase	Nº	Cubre
TestAuth	5	Sin header, header vacío, firma inválida, secret distinto, body modificado tras firmar
TestJsonInvalido	3	Body no JSON, array, vacío
TestPayloadInvalido	3	Sin subscription_id, vacío, whitespace
TestSubInexistente	1	404 con subscription_id desconocido
TestRespuestaCompleta	3	Sin saldo, con saldo+transacciones, límite de 10
TestEstadosSuscripcion	2	canceled / past_due → puede_cancelar=false
TestReadOnly	1	Contar filas antes/después → cero escrituras
TestLegacyEndpointsIntactos	2	/internal/stripe-event y /webhook/stripe siguen registrados
TestEstructuraEsperada	1	telefono presente en respuesta

7. Read-only confirmado

Test **TestReadOnly::test_endpoint_no_modifica_db** cuenta filas en las 4 tablas relevantes (suscripcion_stripe, saldo_creditos, transacciones_credito, evento_stripe_procesado) **antes** y **después** de 3 invocaciones consecutivas del endpoint. Assert antes == después.

Implementación: el endpoint solo ejecuta **SELECT** queries dentro de un *async with async_session()*. No hay *session.add()*, *session.commit()* con cambios, *update()*, *insert()* ni *delete()*.

8. Riesgos abiertos

Riesgo	Severidad	Mitigación
INTERNAL_BRIDGE_SECRET filtrado	Alta	Rotar en Vercel y Render simultáneamente
current_period_end / cancel_at_period_end no en backend	Baja	El landing los obtiene de Stripe SDK en T1.4.D
email=null en respuesta requiere merge en landing Info	Baja	Documentado; el landing tiene session.user.email
Sin rate limiting al endpoint	Bajo	Solo accesible internamente con HMAC; brute force del HMAC es computacionalmente caro
DB query sin límite global de tiempo	Bajo	Las queries son lookups por PK (saldo, sub) o LIMIT 10 (transacciones); riesgo de DoS

9. Próximos pasos para T1.4.D

T1.4.D crea el proxy en el landing: *landing/app/api/dashboard-data/route.ts*.

- Tomar *subscriptionId* de la sesión NextAuth (server-side).

- Reutilizar el helper de T1.3.E *landing/lib/internal-bridge.ts* extendido con un método *fetchUsuarioResumen(subscriptionId)* que firma con HMAC-SHA256(body, INTERNAL_BRIDGE_SECRET) y POSTea a *BACKEND_URL/internal/usuario-resumen*.
- Recibir el JSON del backend.
- Hacer fetch en paralelo a Stripe SDK desde el landing para obtener *current_period_end* y *cancel_at_period_end*.
- Mergear ambas fuentes (backend + Stripe + session.email).
- Retornar al cliente.

Importante para T1.4.D: el landing nunca debe exponer INTERNAL_BRIDGE_SECRET ni STRIPE_SECRET_KEY al cliente. Toda esta lógica corre **server-side** en route.ts.

Restricciones respetadas

- ✓ NO se hizo deploy.
- ✓ NO se mergeó a main.
- ✓ NO se modificó producción.
- ✓ NO se expusieron secretos.
- ✓ NO se creó endpoint público (es /internal/, requiere HMAC).
- ✓ NO se escribió en la base.
- ✓ Tests cubren auth, validación, casos felices y read-only.
- ✓ NO requiere env var nueva (reusa INTERNAL_BRIDGE_SECRET).